AUDIT REPORT · AUD-20261104-43E1

# paiement-api — SEPA transfer microservice — RTS 2024/1774 · Politique interne PDS-2 (Banque Kerlann, fictive)

Banque Kerlann (fictitious) · paiement-api — SEPA transfer microservice

Prepared by: **Attest (AI-assisted)**

Auditor sign-off: **pending (work programme reviewed by Attest CI)**

Owner: **IT department — Payments development team**

Date: **2026-11-04 00:18**

Run: **20261104-001838-43e1**

## 1. Executive summary

OPINION AT TESTING

**Needs improvement**

**Basis for opinion**

7 controls tested (6 conclusive) against: RTS 2024/1774 — article 16 : acquisition, développement et maintenance des systèmes TIC · Politique interne PDS-2 (Banque Kerlann, fictive) — développement sécurisé. Tests run on 2026-11-04 00:18, environment: Demonstration pre-production. The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

**Scope limitation:** Test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

| | | | |
|---|---|---|---|
| **7** controls tested | **6** findings | **0** findings closed and verified | **6** open findings |
| **0** human approvals | **0** sensitive data items masked in evidence | **3 min 56 s** audit duration | **$0.511 *** measured AI cost |



Critical: 0 · High: 3 · Medium: 3 · Low: 0

### Key messages

- 6 findings across 7 controls: 3 high, 3 medium.
- 6 findings remain open, with an action plan, an owner and a due date.
- 1 control needs review: the test and the visual evidence disagree.
- 1 control(s) without visual evidence: verdict rests on the test alone, to be confirmed.

## 2. Scope and method

| | |
|---|---|
| Engagement | AUD-20261104-43E1 |
| Entity | Banque Kerlann (fictitious) |
| System | paiement-api — SEPA transfer microservice |
| System criticality | Supports critical or important functions (DORA) |
| Environment | Demonstration pre-production |
| Owner | IT department — Payments development team |
| Lead auditor | Attest CI |
| Date | 2026-11-04 00:18 |
| Framework | RTS 2024/1774 — article 16 : acquisition, développement et maintenance des systèmes TIC · Politique interne PDS-2 (Banque Kerlann, fictive) — développement sécurisé |
| Audited target | paiement-api code repository (SEPA transfer microservice) |
| Work programme | reviewed by an auditor (Attest CI) · runs/studio/20261104-001838-43e1/catalogue.json |

### In scope

- Source code, configuration and CI pipeline of the repository
- Versioned test datasets

### Out of scope

- Dynamic testing (DAST) and penetration testing
- Runtime and production environments
- Git history

### Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

### Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fixes are drafted by the audit tool itself (self-review threat): closing a finding requires independent approval by the system owner.
- Fictitious entity and data: demonstration.

## 3. Findings overview

| REF. | RULE | TITLE | SEVERITY | TESTED | AFTER | STATUS | DUE DATE |
|---|---|---|---|---|---|---|---|

| | | | | | | |
|---|---|---|---|---|---|---|
| F-01 | PDS-2.2 | TLS certificate verification enforced | High | Non-compliant | Open | 2027-02-02 |
| F-02 | PDS-2.3 | Approved password hashing only | High | Non-compliant | Open | 2027-02-02 |
| F-03 | PDS-2.6 | Synthetic test data only | High | Non-compliant | Open | 2027-02-02 |
| F-04 | PDS-2.4 | CI static security analysis present | Medium | Non-compliant | Open | 2027-05-03 |
| F-05 | PDS-2.5 | Pinned dependencies with CI audit | Medium | Non-compliant | Open | 2027-05-03 |
| F-06 | PDS-2.7 | Authentication success and failure logging | Medium | Non-compliant | Open | 2027-05-03 |
| — | PDS-2.1 | No hardcoded secrets in code | Critical | Needs review | | |

## 4. Detailed findings and controls

### F-01 PDS-2.2 TLS certificate verification enforced

High · Non-compliant · Open

#### CRITERIA

Verify outgoing calls never disable TLS certificate verification.

PDS-2.2 · DORA 9(3)(a) ; RTS 6(2)(a)

Threshold source: PDS-2.2

> *« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »*

#### CONDITION

Observed: `[{"line": 18, "path": "app/payments.py", "text": "response = requests.post(PSP_URL, json=payload, timeout=TIMEOUT_S, verify=False)"}]`

Expected: `Zero matches for verify=False or disabled TLS verification in app/ code.`

Found disabled TLS verification patterns in app/ code.

#### RISK

Disabled TLS verification enables man-in-the-middle interception of SEPA data.

#### RECOMMENDATION

Remove verify=False and enforce default TLS certificate verification.

Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET search for verify\s*=\s*False|ssl\._create_unverified|CERT_NONE|check_hostname\s*=\s*False then GET file for each hit in app/.




**At testing** — The screenshot corroborates the test. Line 18 in app/payments.py shows requests.post with verify=False, confirming disabled TLS verification.
`2026-11-04 00:20:01 · SHA-256 03ffbdd593d56b5c…`

## F-02 PDS-2.3 Approved password hashing only

High | Non-compliant | Open

### CRITERIA

Verify passwords use argon2, bcrypt, scrypt or PBKDF2 and not MD5/SHA-1.
PDS-2.3 · RTS 6(3) et 6(4)
Threshold source: PDS-2.3

> *« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »*

### CONDITION

Observed: `{"matches": [{"line": 8, "path": "app/auth.py", "text": "return hashlib.md5(password.encode()).hexdigest()"}] "weak_password_hits": [{"line": 8, "path": "app/a…`
Expected: `Password hashing uses only argon2/bcrypt/scrypt/PBKDF2; zero MD5/SHA-1 use for security in app/.`
MD5/SHA-1 password hashing found in app/auth.py while only argon2/bcrypt/scrypt/PBKDF2 is allowed.

### RISK

Weak hashes allow password recovery and authentication bypass.

### RECOMMENDATION

Replace MD5/SHA-1 with argon2, bcrypt, scrypt or PBKDF2 for password hashing.
Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET search for argon2|bcrypt|scrypt|pbkdf2|hashlib\.(md5|sha1)\(|Crypto\.Hash\.(MD5|SHA1) then GET file for hits to confirm password context.




**At testing** — The screenshot corroborates the test. Line 8 of app/auth.py implements hash_password with hashlib.md5 for password verification.
2026-11-04 00:21:54 · SHA-256 9b670c1eafd915cb…

## F-03 PDS-2.6 Synthetic test data only

High · Non-compliant · Open

### CRITERIA

Verify test data is declared synthetic and no production dump is versioned.
PDS-2.6 · RTS 16(5)(a)
Threshold source: PDS-2.6

> *« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »*

### CONDITION

Observed: `{"target": "tests/fixtures.json", "fixture_found": false, "synthetic_regex": false, "synthetic_bool": false, "synthetic_matches": 1, "dump_files": [], "dump_mat…`
Expected: `Test fixtures contain "synthetic": true; zero versioned production exports or real IBAN datasets.`
Test fixture does not declare synthetic true.

### RISK

Production data in test exposes confidentiality and violates anonymisation.

### RECOMMENDATION

Replace test data with synthetic data flagged synthetic true and remove production exports.
Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET tree and search for synthetic and GET file for tests/fixtures to verify "synthetic": true, and search for production dump patterns.

⚠ Visual evidence unavailable; verdict rests on the test alone: RuntimeError : capture impossible : http://127.0.0.1:5050/repo/paiement-api/view?path=tests/fixtures.json → HTTP 404

## F-04 PDS-2.4 CI static security analysis present

Medium · Non-compliant · Open

### CRITERIA

Verify CI runs bandit, semgrep or CodeQL on every change.

### CONDITION

Observed: `{"workflows": [".github/workflows/ci.yml"], "analysis": {".github/workflows/ci.yml": {"tool": null,`

PDS-2.4 · RTS 16(3)
Threshold source: PDS-2.4

> *« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »*

### CONDITION

`"has_on": true, "has_push": true, "has_pull_request": false,…`
Expected: `At least one workflow runs bandit or semgrep or CodeQL on push/pull_request.`
No workflow in .github/workflows/ runs bandit, semgrep or CodeQL on push and pull_request.

### RISK

Missing static analysis leaves code vulnerabilities undetected.

### RECOMMENDATION

Add bandit, semgrep or CodeQL step to CI on every change.
Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET tree to list .github/workflows/ files, then GET file for each workflow and check for bandit|semgrep|CodeQL and on: [push, pull_request].




**At testing** — The screenshot corroborates the test. The workflow triggers only on push and runs only checkout, setup-python, pip install and pytest with no bandit, semgrep or CodeQL step.
`2026-11-04 00:20:13 · SHA-256 cfbb2e4159bb03c3…`

## F-05 PDS-2.5 Pinned dependencies with CI audit

Medium · Non-compliant · Open

### CRITERIA

Verify exact version pinning and CI dependency audit.
PDS-2.5 · RTS 16(4) et 16(8)
Threshold source: PDS-2.5

> *« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »*

### CONDITION

Observed: `{"requirements_lines": ["flask", "requests>=2.0", "pyjwt==2.8.0"], "unpinned": ["flask", "requests>=2.0"], "workflow_files": [".github/workflows/ci.yml"], "audi…`
Expected: `All dependencies use == exact pin; CI contains pip-audit or equivalent audit step.`
Found 2 unpinned dependencies out of 3 and no CI audit step found.

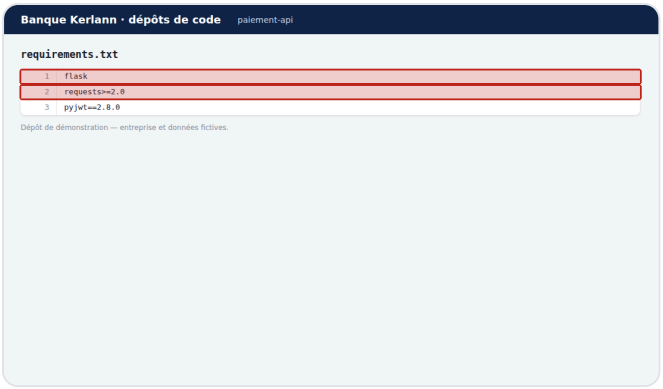
### RISK

Unpinned or unaudited dependencies allow vulnerable package deployment.

### RECOMMENDATION

Pin all dependencies with == and add pip-audit step in CI.
Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET file for requirements.txt and verify each line matches paquet==version, then GET tree and file for .github/workflows/ and search for pip-audit|safety|dependabot|osv-scanner.




**At testing** — The screenshot corroborates the test. Screenshot shows flask with no version and requests>=2.0, confirming two unpinned dependencies.
2026-11-04 00:21:30 · SHA-256 94071ff0cc3ec301…

## F-06 PDS-2.7 Authentication success and failure logging

Medium | Non-compliant | Open

### CRITERIA

Verify application logs both successful and failed authentications.
PDS-2.7 · RTS 12(2)(c)(i)
Threshold source: PDS-2.7

> *« Les réussites et les échecs d'authentification sont journalisés par l'application. »*

### CONDITION

Observed: `{"path": "app/payments.py", "success_log": "", "failure_log": "", "any_success": false, "any_failure": false, "match_count": 2}`
Expected: `Code contains log statements on both authentication success and failure paths.`
app/payments.py contains no success or failure authentication log statements.

### RISK

Missing auth logs prevents detection of brute-force and incident response.

### RECOMMENDATION

Add logging for both authentication successes and failures.
Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET search for logger|logging|log.*auth|login.*(success|fail)|401|403 in app/ then GET file for hits to confirm both success and failure paths logged.




**At testing** — The screenshot corroborates the test. app/payments.py shows only a transfer initiation log and no authentication success or failure logs.
2026-11-04 00:22:34 · SHA-256 168099bdf34367c6…

## PDS-2.1 No hardcoded secrets in code

Critical | Needs review

### CRITERIA

Verify no password, key or token is written in clear text in versioned code.

PDS-2.1 · RTS 7(2)

Threshold source: PDS-2.1

> *« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »*

### CONDITION

Observed: `[{"path": "app/auth.py", "line": 15, "text": " return operator[\"password_hash\"] == hash_password(password)"}, {"path": "app/config.py", "line": 7, "text": …`

Expected: `Zero hardcoded secret values; all secrets referenced via os.environ or vault; no private keys versioned.`

Found 3 hardcoded secret values in 3 files with 6 keyword matches.

### RISK

Hardcoded secrets allow credential theft and unauthorized transfers.

### RECOMMENDATION

Remove hardcoded secrets and load them from vault or environment variables.

Test procedure: GET tree to list files, then GET search with regex for password|passwd|secret|api[_-]?key|token|BEGIN.*PRIVATE KEY and GET file for hits to verify whether value comes from os.environ or vault client.




**At testing** — The screenshot does NOT corroborate the test. The screenshot shows app/auth.py lines 1-15 with only code references to password_hash and no hardcoded secret value visible.

2026-11-04 00:20:08 · SHA-256 f91409396e03e898…

# Appendices

## A. Traceability matrix

| REQUIREMENT | RULE | CONTROL | SCRIPT (SHA-256) | RESULT |
|---|---|---|---|---|
| RTS 7(2) | PDS-2.1 | C1 · No hardcoded secrets in code | c709a0863cb36601 · written by AI for this engagement | Needs review |
| DORA 9(3)(a) ; RTS 6(2)(a) | PDS-2.2 | C2 · TLS certificate verification enforced | 1d66e6b303b82a64 · written by AI for this engagement | Non-compliant |
| RTS 6(3) et 6(4) | PDS-2.3 | C3 · Approved password hashing only | d3d09e4b3e9e1704 · written by AI for this engagement | Non-compliant |
| RTS 16(3) | PDS-2.4 | C4 · CI static security analysis present | fc4504947a6fcede · written by AI for this engagement | Non-compliant |
| RTS 16(4) et 16(8) | PDS-2.5 | C5 · Pinned dependencies with CI audit | f2158d7960a2dfb8 · written by AI for this engagement | Non-compliant |
| RTS 16(5)(a) | PDS-2.6 | C6 · Synthetic test data only | 29a37bfee74b2012 · written by AI for this engagement | Non-compliant |
| RTS 12(2)(c)(i) | PDS-2.7 | C7 · Authentication success and failure logging | cd3b57daefee82e8 · written by AI for this engagement | Non-compliant |

## B. Evidence register

| FILE | | | SHA-256 |
|---|---|---|---|
| evidence/C1_before.png | C1 · At testing | 2026-11-04 00:20:08 | f91409396e03e898a5846d63d299cb8871943865c11b9d24f72d4fd14cdd77ca |
| evidence/C2_before.png | C2 · At testing | 2026-11-04 00:20:01 | 03ffbdd593d56b5c2617e7935507798b8d74d6a1c2264c4c5f0bd6bf9de88b32 |
| evidence/C3_before.png | C3 · At testing | 2026-11-04 00:21:54 | 9b670c1eafd915cb6df201edf42dc67d9cd479c769ad7b5f49bc574e294bd891 |
| evidence/C4_before.png | C4 · At testing | 2026-11-04 00:20:13 | cfbb2e4159bb03c3141060aef9f46daabbc947f5fddcfe451d46811938fcb0b0 |
| evidence/C5_before.png | C5 · At testing | 2026-11-04 00:21:30 | 94071ff0cc3ec3013b5c4620d989ef9e69def04847069f8c7a03fba625a6574f |
| evidence/C7_before.png | C7 · At testing | 2026-11-04 00:22:34 | 168099bdf34367c6af05eb21777c45a42a9ffe770d00194506fe75f1de923b8b |

## C. AI usage, costs and human oversight

| MODEL | CALLS | INPUT TOKENS | OUTPUT TOKENS | IMAGES | COST (USD) |
|---|---|---|---|---|---|
| muse-spark-1.3 | 14 | 18,133 | 114,833 | 0 | 0.5107 |

| | | | | | |
|---|---|---|---|---|---|
| sam-3.1 | 5 | 0 | 0 | 5 | price not published |
| **Total** | | | | | **0.5107** |

* sam-3.1: price not published (pricing.toml)

## Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

## D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`68f27a0dce2b463954a76cfc5f5b3715a47fc9c60aede32fdff9cfcbe3c231cb`

## F. Framework coverage

20 requirements read: 11 tested automatically (7 controls; 4 regulation clauses covered through the policy), 9 left to document review, 0 to interviews, 0 rejected for lack of an exact quote. Attest only covers the first group.

| REF. | TEXT (VERIFIED QUOTE) | TESTABILITY | CONTROL | |
|---|---|---|---|---|
| RTS 16(1) | « financial entities shall develop, document and implement a policy governing the acquisition, development, and maintenance of ICT systems. » | **document review** | 0 | Existence and content of a policy requires document review and is not visible in code. |
| RTS 16(1)(a) | « identify security practices and methodologies relating to the acquisition, development, and maintenance of ICT systems; » | **document review** | 0 | Policy content can only be verified by reviewing the policy document. |
| RTS 16(1)(c) | « specify measures to mitigate the risk of unintentional alteration or intentional manipulation of the ICT systems during development, maintenance, and deployment. » | **document review** | 0 | Measures description requires policy and procedure documents, not code alone. |
| RTS 16(2) | « financial entities shall develop, document, and implement an ICT systems' acquisition, development, and maintenance procedure for the testing and approval of all ICT systems prior to their use and after maintenance. » | **document review** | 0 | Testing and approval records require document review beyond read-only code access. |
| RTS 16(3) | « the procedure shall contain source code reviews covering both static and dynamic testing, including security testing for internet-exposed systems and applications. » | **tested automatically** | → PDS-2.4 | Static testing execution is visible in CI configuration testable via the repository interface. |

| | | | | |
|---|---|---|---|---|
| RTS 16(3)(a) | « identify and analyse vulnerabilities and anomalies in the source code; » | **document review** | 0 | Identification records and analysis reports require document review, not just code search. |
| RTS 16(3)(b) | « adopt an action plan to address those vulnerabilities and anomalies; » | **document review** | 0 | An action plan is a governance document not observable in the code repository. |
| RTS 16(3)(c) | « monitor the implementation of that action plan. » | **document review** | 0 | Monitoring requires follow-up records and tracking, not testable via read-only code. |
| RTS 16(4) | « the procedure shall contain security testing of software packages no later than at the integration phase. » | **tested automatically** | → PDS-2.5 | Integration-phase package auditing is visible in CI and dependency files via the repository interface. |
| RTS 16(5)(a) | « non-production environments only store anonymised, pseudonymised, or randomised production data; » | **tested automatically** | → PDS-2.6 | Versioned test data content is searchable in the repository to verify synthetic nature. |
| RTS 16(5)(b) | « financial entities are to protect the integrity and confidentiality of data in non-production environments. » | **document review** | 0 | Protection measures for environments require document and configuration review beyond code content. |
| RTS 16(7) | « the procedure shall include controls to protect the integrity of source code of ICT systems that are developed in-house or by an ICT third-party service provider. » | **document review** | 0 | Source-code integrity controls require branch protection and signing records not exposed by file content API. |
| RTS 16(8) | « proprietary software and, where feasible, the source code provided by ICT third-party service providers, as well as source code coming from open-source projects, are to be analysed and tested in accordance with paragraph » | **tested automatically** | → PDS-2.5 | Dependency pinning and audit in CI visible via repository is the testable implementation of this clause. |
| PDS-2.1 | « Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. » | **tested automatically** | 1 | Hardcoded secrets patterns are searchable and verifiable via file content in the repository. |
| PDS-2.2 | « Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). » | **tested automatically** | 1 | TLS verification disabling is detectable by searching code for verify=False and TLS options. |

| | | | | |
|---|---|---|---|---|
| PDS-2.3 | « Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. » | **tested automatically** | 1 | Hashing library imports and MD5/SHA-1 usage are searchable in source files. |
| PDS-2.4 | « La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. » | **tested automatically** | 1 | CI workflow files listing jobs are readable via tree and file in the repository. |
| PDS-2.5 | « Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). » | **tested automatically** | 1 | requirements.txt pinning and CI audit steps are readable via tree, file and search. |
| PDS-2.6 | « Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. » | **tested automatically** | 1 | Test fixtures and synthetic flag are searchable in tests/ and versioned files. |
| PDS-2.7 | « Les réussites et les échecs d'authentification sont journalisés par l'application. » | **tested automatically** | 1 | Logging calls for authentication events are searchable in application source. |